

Clase 092 — Inyección SQL avanzada y ciega (blind)

Parte: 4 — Seguridad de aplicaciones web · Fuente: *The Web Application Hacker's Handbook (Stuttard & Pinto)* 🕒 Duración estimada: 130 min · Nivel: Avanzado

Objetivo

Explotar SQLi cuando **no hay salida directa de datos**: inyección ciega booleana, basada en tiempo y out-of-band. Estas técnicas permiten extraer información incluso cuando la aplicación no muestra errores ni resultados, algo muy común en aplicaciones reales bien configuradas.

⚠️ **Ética**: exclusivamente en DVWA, Juice Shop, PortSwigger labs u objetivos con autorización expresa.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Distinguir** blind booleana, temporal y out-of-band.
2. **Extraer** datos bit a bit con condiciones booleanas.
3. **Confirmar** inyección con retardos temporales (`SLEEP` , `WAITFOR`).
4. **Aplicar** exfiltración out-of-band vía DNS/HTTP cuando es posible.
5. **Estimar** el coste y automatizar la extracción.

Temas

#	Tema	Por qué importa
1	Blind booleana	Extracción sin ver datos
2	Funciones SUBSTRING/ASCII	Leer carácter a carácter
3	Blind temporal	Cuando ni la lógica cambia
4	Out-of-band (DNS/HTTP)	Exfiltración por canal alternativo
5	Segundo orden (second-order)	El payload se ejecuta después
6	Automatización con scripts	La extracción manual es lenta
7	Diferencias por motor	SLEEP vs. WAITFOR vs. pg_sleep

Definiciones y características

- **Blind SQLi**: la respuesta no incluye datos, solo cambia de forma observable. Característica: se infiere info por diferencias sutiles.

- **Booleana:** se plantean condiciones verdadero/falso. Característica: la página cambia según el resultado.
- **Basada en tiempo:** se induce un retardo condicional. Característica: útil cuando no hay ninguna diferencia visible.
- **Out-of-band (OOB):** los datos salen por DNS/HTTP a un servidor del atacante. Característica: requiere que el motor pueda iniciar conexiones.
- **Second-order:** el input se almacena y se ejecuta en otra operación posterior. Característica: difícil de detectar en el punto de entrada.
- **Oráculo booleano:** cualquier señal binaria fiable (código, longitud, contenido). Característica: base de la extracción bit a bit.

Herramientas y preparación

- **PortSwigger Web Security Academy** (labs de blind SQLi, gratis con cuenta).
- **Burp Intruder/Repeater** para automatizar condiciones.
- **Burp Collaborator** o un servidor DNS propio para OOB.

Laboratorio guiado

 Solo en los labs autorizados.

1. Elige el lab "Blind SQL injection with conditional responses" de PortSwigger.
2. Identifica el oráculo: un mensaje que aparece solo cuando la condición es verdadera.
3. Confirma inyección con `' AND 1=1-- -` (aparece) vs. `' AND 1=2-- -` (no aparece).
4. Extrae un carácter con:

```
' AND SUBSTRING((SELECT password FROM users WHERE username='administrator'),1,1)='a'-- -
```

5. Itera posición y valor (con Intruder, cluster bomb) para reconstruir la contraseña.
6. Practica el lab de **blind temporal**: `'; IF (condición) WAITFOR DELAY '0:0:5'-- -` (MSSQL) o `' AND SLEEP(5)-- -` (MySQL).
7. En el lab OOB, provoca una interacción DNS hacia Collaborator para exfiltrar datos.

Ejercicios

1. Reconstruye una contraseña de 20 caracteres con blind booleana y mide cuántas peticiones costó.
2. Optimiza la extracción usando búsqueda binaria (`>` en vez de `=`).
3. Escribe el payload temporal equivalente para MySQL, MSSQL y PostgreSQL.
4. Explica por qué la blind temporal es la más ruidosa y lenta.
5. Diseña un oráculo booleano a partir del tamaño de la respuesta.
6. Describe un escenario de second-order SQLi con un caso de registro de usuario.

Reto verificable

Extrae la contraseña completa del usuario `administrator` en un lab de blind SQLi de PortSwigger usando **solo** condiciones booleanas automatizadas. **Criterio de aceptación:** entregas la contraseña recuperada, la

configuración de Intruder (posiciones y payload set) y el número de peticiones necesarias, resolviendo el lab.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
El oráculo no es fiable	Elige una señal más estable (código o longitud)
Extracción lentísima	Usa búsqueda binaria y concurrencia
SLEEP no funciona	Motor distinto; usa la función correcta
OOB sin interacciones	El motor no permite conexiones salientes
Resultados intermitentes	Rate limiting; añade delays y reintentos

Preguntas frecuentes

? ¿Cuándo uso temporal en vez de booleana? Cuando no hay ninguna diferencia observable en la respuesta salvo el tiempo. Es más lenta, úsala como último recurso.

? ¿Qué es exactamente second-order? El input malicioso se guarda sin ejecutarse y detona en otra consulta posterior (por ejemplo, al mostrar el perfil).

? ¿Por qué la búsqueda binaria acelera tanto? Reduce las pruebas por carácter de ~128 a ~7 comparaciones ($\log_2$), un ahorro enorme.

Referencias

- Stuttard & Pinto, *The Web Application Hacker's Handbook*, cap. 9.
- PortSwigger Blind SQL injection: <https://portswigger.net/web-security/sql-injection/blind>
- OWASP Testing for SQL Injection (WSTG).

Siguiente clase

Clase 093 - SQLMap